

Министерство науки и высшего образования Российской Федерации
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ
ОБРАЗОВАТЕЛЬНОЕ УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ
НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ
ИТМО
ITMO University

Практическая работа №4

По дисциплине Информационная безопасность

Тема работы Анализ инцидента по журналам аудита

Обучающийся Сакулин Иван Михайлович

Факультет Факультет прикладной информатики

Группа К3321

Направление подготовки 11.03.02 Инфокоммуникационные технологии и
системы связи

Образовательная программа Программирование в инфокоммуникацион-
ных системах

Обучающийся

(дата)

(подпись)

Сакулин И.М.

(Ф.И.О.)

Руководитель

(дата)

(подпись)

Пикуль А.С.

(Ф.И.О.)

СОДЕРЖАНИЕ

Стр.

ВВЕДЕНИЕ	3
1 ХОД РАБОТЫ.....	4
1.1 Первичный осмотр журнала	4
1.2 Обнаружение атаки	5
1.2.1 Количество неудачных попыток	5
1.2.2 IP-адреса источников	6
1.2.3 Перебираемые учётные записи	6
1.2.4 Интенсивность атаки	7
1.3 Установление факта компрометации	8
1.4 Действия злоумышленника после проникновения	8
1.4.1 Попытки повышения привилегий	9
1.4.2 Создание учётной записи-бэкдора	10
1.4.3 Повторный вход по ключу	11
1.5 Отчёт аудитора	12
1.5.1 Хронология инцидента	12
1.5.2 Индикаторы компрометации	12
1.5.3 Оценка последствий	12
1.5.4 Рекомендации	13
ЗАКЛЮЧЕНИЕ	14

ВВЕДЕНИЕ

Цель работы: научиться читать системные журналы аутентификации Linux, находить в них следы атаки, восстанавливать хронологию инцидента и формулировать выводы аудитора.

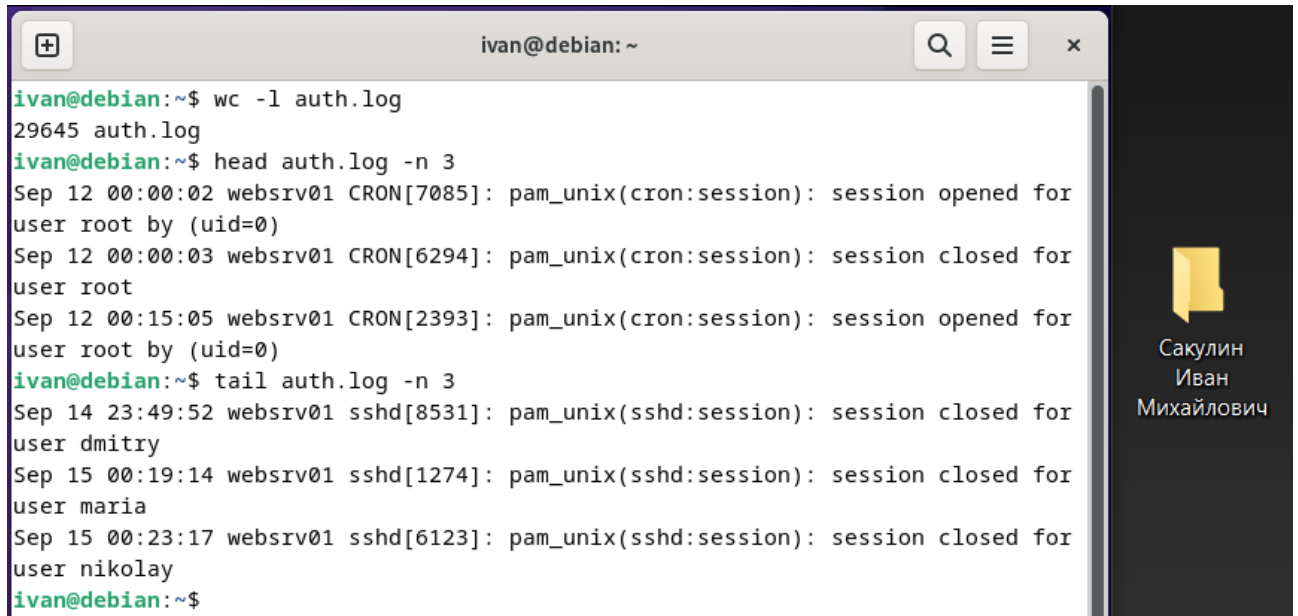
Задачи:

- 1) провести первичный осмотр журнала `auth.log`;
- 2) обнаружить признаки атаки (перебор паролей);
- 3) установить факт компрометации и выявить злоумышленника;
- 4) восстановить действия злоумышленника после проникновения;
- 5) составить отчёт аудитора с рекомендациями.

1 ХОД РАБОТЫ

1.1 Первичный осмотр журнала

Журнал содержит 29 645 строк. Первая запись зафиксирована в полночь с 11 на 12 сентября, последняя — в полночь с 14 на 15 сентября. На рисунке 1 показан результат подсчёта строк и просмотр начала и конца файла.



```
ivan@debian: ~  
ivan@debian:~$ wc -l auth.log  
29645 auth.log  
ivan@debian:~$ head auth.log -n 3  
Sep 12 00:00:02 webserv01 CRON[7085]: pam_unix(cron:session): session opened for  
user root by (uid=0)  
Sep 12 00:00:03 webserv01 CRON[6294]: pam_unix(cron:session): session closed for  
user root  
Sep 12 00:15:05 webserv01 CRON[2393]: pam_unix(cron:session): session opened for  
user root by (uid=0)  
ivan@debian:~$ tail auth.log -n 3  
Sep 14 23:49:52 webserv01 sshd[8531]: pam_unix(sshd:session): session closed for  
user dmitry  
Sep 15 00:19:14 webserv01 sshd[1274]: pam_unix(sshd:session): session closed for  
user maria  
Sep 15 00:23:17 webserv01 sshd[6123]: pam_unix(sshd:session): session closed for  
user nikolay  
ivan@debian:~$
```

Рисунок 1 — Подсчёт строк, вывод начала и конца журнала

При беглом просмотре файла с помощью `less auth.log` (рисунок 2) выявлены следующие типы событий:

- неудачные попытки входа (строки с `Failed password`);
- успешные входы (`Accepted`);
- сессионные записи (`session opened/closed`);
- выполнение команд `sudo`;
- системные события `CRON`.

Наибольший объём занимают неудачные попытки аутентификации, что указывает на возможную атаку перебора паролей.

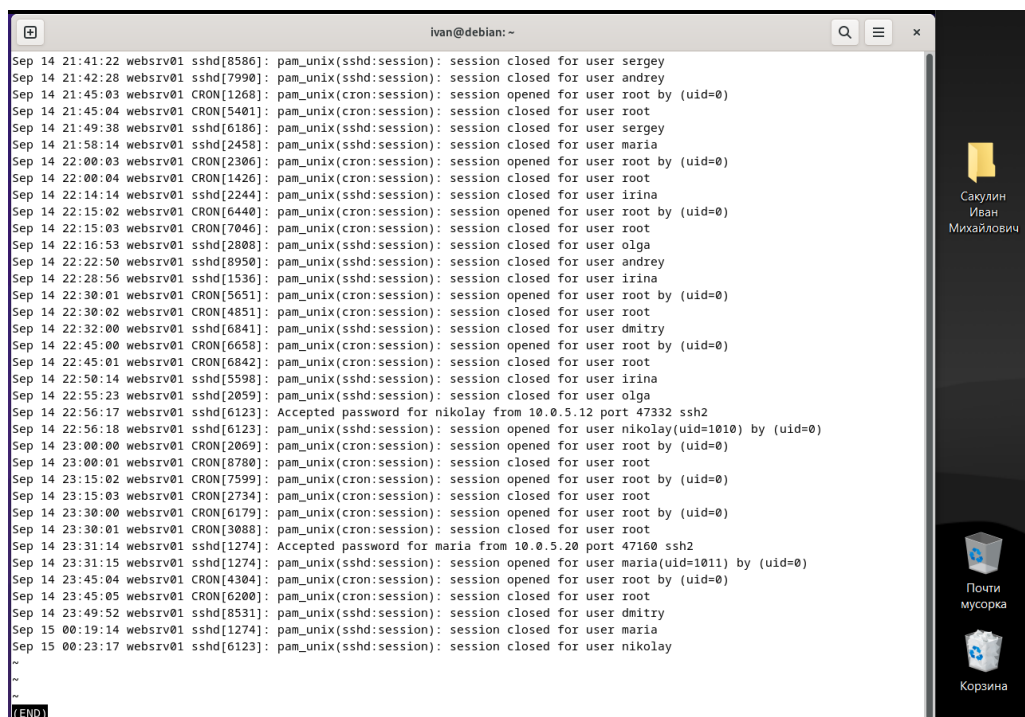


Рисунок 2 — Беглый просмотр журнала в less

1.2 Обнаружение атаки

1.2.1 Количество неудачных попыток

Был выполнен подсчёт всех записей о неудачных попытках входа. Результат (рисунок 3) составил 13 800 попыток, что составляет почти половину всех записей. Такое число ошибочных вводов пароля за трое суток не может быть объяснено случайными ошибками пользователей и является явным признаком автоматизированного перебора.

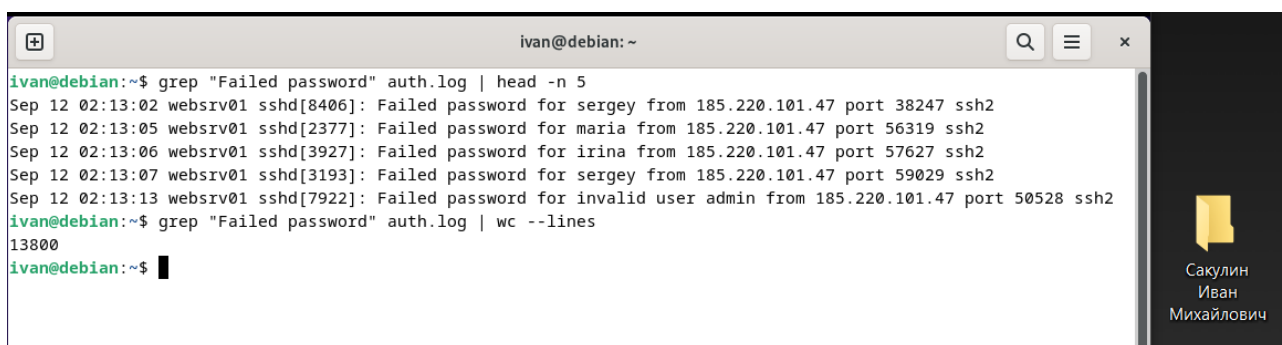


Рисунок 3 — Количество неудачных попыток входа

1.2.2 IP-адреса источников

Выполнена группировка попыток по IP-адресам. На рисунке 4 видно, что перебор вёлся с шести внешних IP-адресов. Наибольшее число попыток (около 5 000) пришлось на адрес 185.220.101.47, однако, как будет показано далее, успешный вход был совершён с другого адреса.



```
ivan@debian: ~  
ivan@debian:~$ grep "Failed password" auth.log | awk '{for(i=1;i<=NF;i++) if($i=="from") print $(i+1)}' | sort | uniq -c | sort -nr  
3500 185.220.101.47  
3000 89.248.165.12  
2400 77.91.124.55  
1900 218.92.0.201  
1600 45.155.205.233  
1400 141.98.10.60  
ivan@debian:~$
```

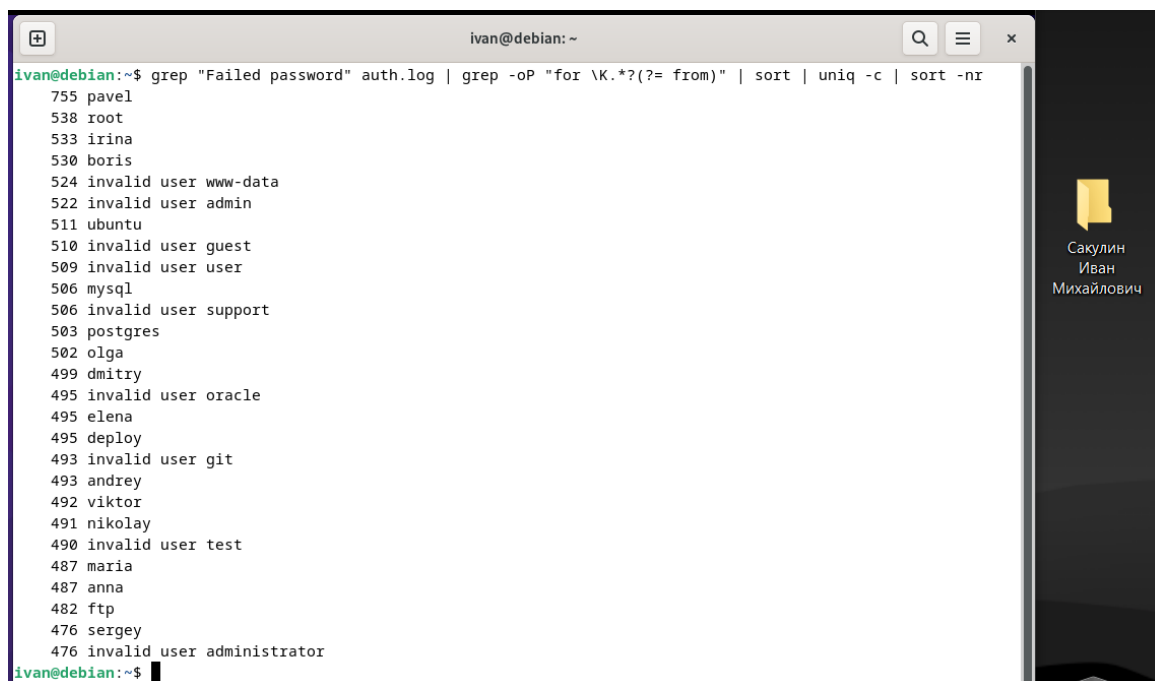
The screenshot shows a terminal window with the command and its output. The output lists six IP addresses with their corresponding number of failed password attempts, sorted in descending order. The IP address 185.220.101.47 has the highest number of attempts (3500).

IP-адрес	Количество попыток
185.220.101.47	3500
89.248.165.12	3000
77.91.124.55	2400
218.92.0.201	1900
45.155.205.233	1600
141.98.10.60	1400

Рисунок 4 — IP-адреса источников неудачных попыток и количество попыток

1.2.3 Перебираемые учётные записи

Получен список имён пользователей, по которым велась атака. Результат (рисунок 5) показывает 18 существующих учётных записей (без пометки `invalid user`) и 9 несуществующих. Перебор по существующим пользователям опаснее, так как злоумышленник пытается подобрать пароль к реальным учётным записям.

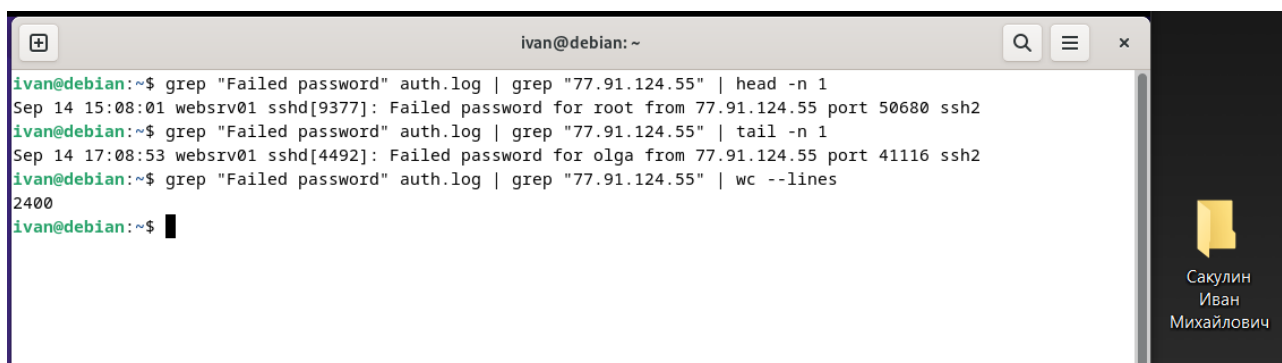


```
ivan@debian: ~  
ivan@debian:~$ grep "Failed password" auth.log | grep -oP "for \K.*?(?= from)" | sort | uniq -c | sort -nr  
755 pavel  
538 root  
533 irina  
530 boris  
524 invalid user www-data  
522 invalid user admin  
511 ubuntu  
510 invalid user guest  
509 invalid user user  
506 mysql  
506 invalid user support  
503 postgres  
502 olga  
499 dmitry  
495 invalid user oracle  
495 elena  
495 deploy  
493 invalid user git  
493 andrey  
492 viktor  
491 nikolay  
490 invalid user test  
487 maria  
487 anna  
482 ftp  
476 sergey  
476 invalid user administrator  
ivan@debian:~$
```

Рисунок 5 — Учётные записи, подвергшиеся перебору, и количество попыток

1.2.4 Интенсивность атаки

Для оценки длительности и интенсивности выбран IP-адрес 77.91.124.55, который в дальнейшем оказался источником успешного входа. Первая неудачная попытка с этого адреса зафиксирована 14 сентября в 15:08, последняя — в 17:08. Длительность атаки составила 2 часа, за которые было совершено около 2400 попыток (интенсивность примерно 20 попыток в минуту). Скриншот с фильтрацией по этому IP приведён на рисунке 6.



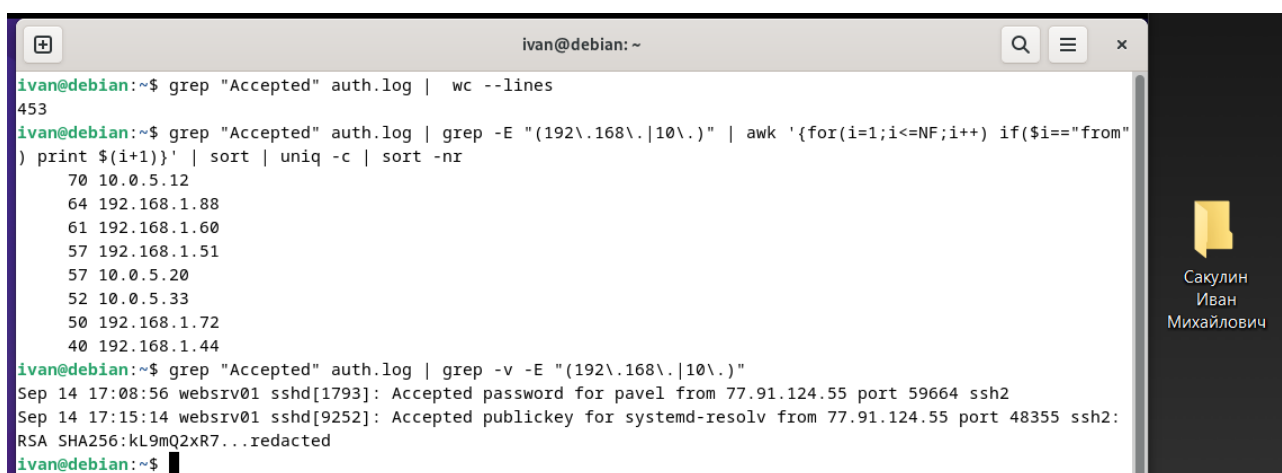
```
ivan@debian: ~  
ivan@debian:~$ grep "Failed password" auth.log | grep "77.91.124.55" | head -n 1  
Sep 14 15:08:01 webserv01 sshd[9377]: Failed password for root from 77.91.124.55 port 50680 ssh2  
ivan@debian:~$ grep "Failed password" auth.log | grep "77.91.124.55" | tail -n 1  
Sep 14 17:08:53 webserv01 sshd[4492]: Failed password for olga from 77.91.124.55 port 41116 ssh2  
ivan@debian:~$ grep "Failed password" auth.log | grep "77.91.124.55" | wc --lines  
2400  
ivan@debian:~$
```

Рисунок 6 — Фильтрация по IP-адресу 77.91.124.55 для оценки интенсивности

1.3 Установление факта компрометации

Всего в журнале зафиксировано 453 успешных входа (Accepted). Большая часть из них выполнена с внутренних адресов (сети 192.168.* и 10.*), что соответствует легитимной активности сотрудников.

Далее были выделены внешние успешные входы. На рисунке 7 показаны результаты: обнаружены две записи с внешнего IP-адреса 77.91.124.55, который ранее фигурировал в списке источников неудачных попыток.



```
ivan@debian: ~  
ivan@debian:~$ grep "Accepted" auth.log | wc --lines  
453  
ivan@debian:~$ grep "Accepted" auth.log | grep -E "(192\.168\.|10\.)" | awk '{for(i=1;i<=NF;i++) if($i=="from")  
) print $(i+1)}' | sort | uniq -c | sort -nr  
70 10.0.5.12  
64 192.168.1.88  
61 192.168.1.60  
57 192.168.1.51  
57 10.0.5.20  
52 10.0.5.33  
50 192.168.1.72  
40 192.168.1.44  
ivan@debian:~$ grep "Accepted" auth.log | grep -v -E "(192\.168\.|10\.)"  
Sep 14 17:08:56 webserv01 sshd[1793]: Accepted password for pavel from 77.91.124.55 port 59664 ssh2  
Sep 14 17:15:14 webserv01 sshd[9252]: Accepted publickey for systemd-resolv from 77.91.124.55 port 48355 ssh2:  
RSA SHA256:kL9mQ2xR7...redacted  
ivan@debian:~$
```

Рисунок 7 — Успешные входы с внешних адресов (выделены)

Первая из этих записей – успешный вход по паролю под учётной записью **pavel** в 17:08:56. Именно этот момент является моментом компрометации. Учётная запись **pavel** существовала в системе (не была помечена как **invalid user**) и активно перебиралась, что подтверждается данными из предыдущего раздела. Злоумышленнику удалось подобрать пароль именно для этой учётной записи.

1.4 Действия злоумышленника после проникновения

После успешного входа были зафиксированы следующие события (все они приведены в хронологическом порядке на рисунке 8):

- 1) **17:08:56** — вход по паролю под пользователем **pavel**;
- 2) **17:08:57** — открытие сессии для **pavel**;

- 3) **17:09:14** — запрос подсистемы **sftp** (возможная попытка передачи файлов);
- 4) **17:09:49** — попытка выполнения **sudo cat /etc/shadow**, которая завершилась ошибкой: **user NOT in sudoers**;
- 5) **17:09:55** — повторная попытка **sudo** с пометкой **authentication failure**;
- 6) **17:11:17** — создание нового пользователя **systemd-resolv** с **UID=0** и **GID=0**;
- 7) **17:11:22** — смена пароля для созданного пользователя;
- 8) **17:12:02** — закрытие сессии **pavel**;
- 9) **17:15:14** — повторный вход, но уже под пользователем **systemd-resolv** по публичному ключу;
- 10) **17:23:14** — закрытие сессии **systemd-resolv**.

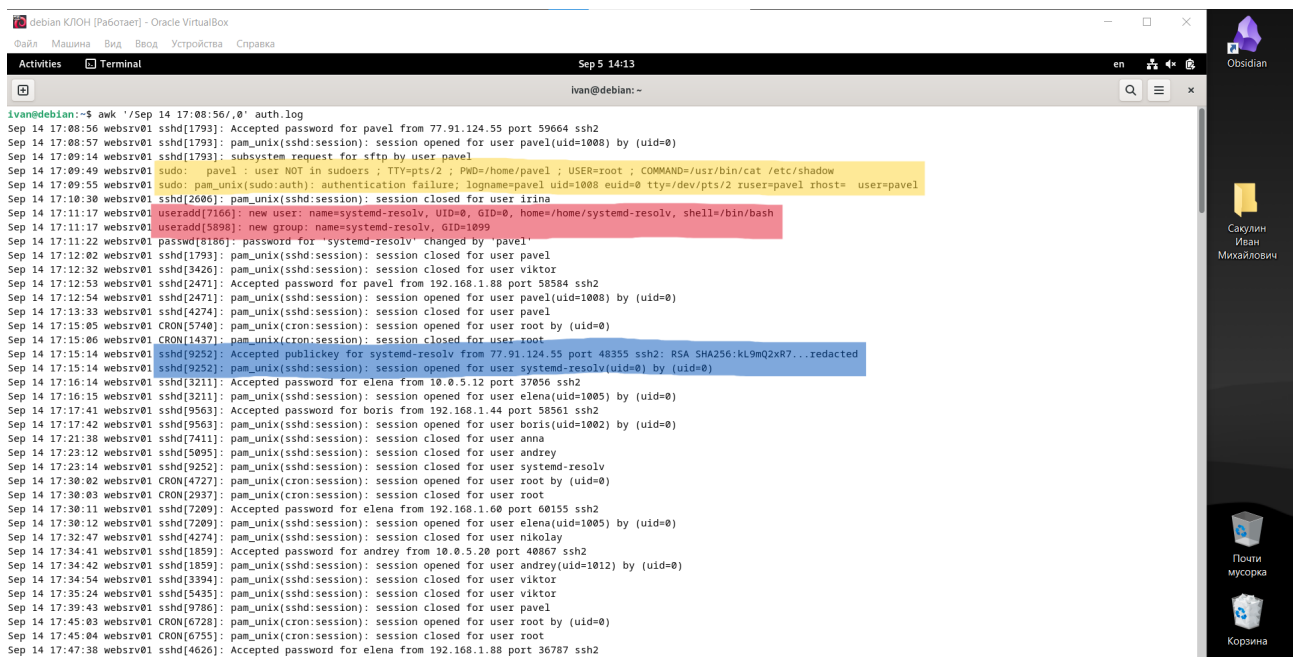
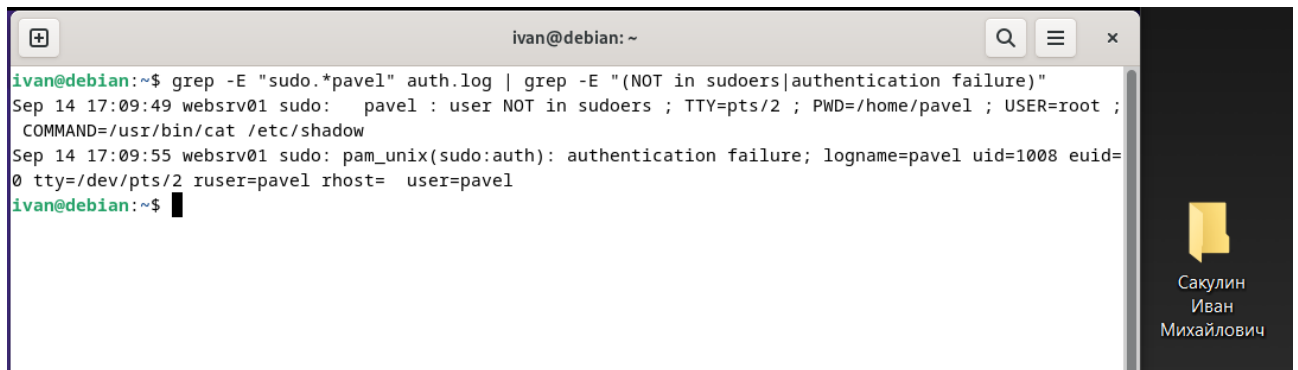


Рисунок 8 — Ключевые события после компрометации

1.4.1 Попытки повышения привилегий

Злоумышленник дважды пытался выполнить команду **sudo cat /etc/shadow** (рисунок 9): первая попытка (17:09:49) завершилась отказом с сообщением **NOT in sudoers**; вторая (17:09:55) — с **authentication failure**.

Цель этих действий — получить содержимое файла `/etc/shadow`, в котором хранятся хеши паролей всех пользователей. Обладая хешами, злоумышленник может попытаться подобрать пароли офлайн (атака перебора). Однако повышение привилегий не удалось, так как пользователь `pavel` не был включён в группу `sudo` и не знал пароля `root`.

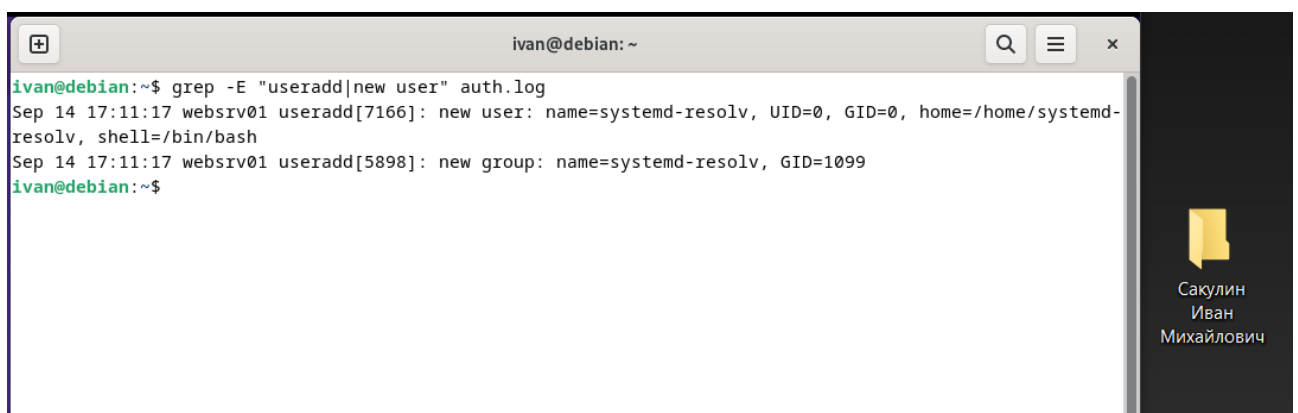
A terminal window titled 'ivan@debian: ~' showing the output of a command: `grep -E "sudo.*pavel" auth.log | grep -E "(NOT in sudoers|authentication failure)"`. The output shows two log entries: one where 'pavel' was not in the sudoers file and another where authentication failed. The user 'ivan' is logged in as 'ivan@debian' with a shell prompt.

```
ivan@debian:~$ grep -E "sudo.*pavel" auth.log | grep -E "(NOT in sudoers|authentication failure)"
Sep 14 17:09:49 webserv01 sudo:  pavel : user NOT in sudoers ; TTY=pts/2 ; PWD=/home/pavel ; USER=root ;
COMMAND=/usr/bin/cat /etc/shadow
Sep 14 17:09:55 webserv01 sudo: pam_unix(sudo:auth): authentication failure; logname=pavel uid=1008 euid=
0 tty=/dev/pts/2 ruser=pavel rhost=  user=pavel
ivan@debian:~$
```

Рисунок 9 — Неудачные попытки sudo (NOT in sudoers и authentication failure)

1.4.2 Создание учётной записи-бэкдора

В 17:11:17 была выполнена команда `useradd` с параметрами, создавшими пользователя `systemd-resolv` с `UID=0` и `GID=0` (рисунок 10). Это означает, что новая учётная запись получила те же привилегии, что и `root`, но при этом не была явно добавлена в `sudoers`. Такая запись позволяет обходить стандартные механизмы контроля доступа и оставаться незамеченной для администраторов, проверяющих только группу `sudo`.

A terminal window titled 'ivan@debian: ~' showing the output of the command: `grep -E "useradd|new user" auth.log`. The output shows two log entries: one for creating a new user 'systemd-resolv' with UID=0 and GID=0, and another for creating a new group 'systemd-resolv' with GID=1099. The user 'ivan' is logged in as 'ivan@debian' with a shell prompt.

```
ivan@debian:~$ grep -E "useradd|new user" auth.log
Sep 14 17:11:17 webserv01 useradd[7166]: new user: name=systemd-resolv, UID=0, GID=0, home=/home/systemd-
resolv, shell=/bin/bash
Sep 14 17:11:17 webserv01 useradd[5898]: new group: name=systemd-resolv, GID=1099
ivan@debian:~$
```

Рисунок 10 — Создание пользователя `systemd-resolv` с `UID=0`

1.4.3 Повторный вход по ключу

Через несколько минут (17:15:14) злоумышленник вошёл в систему уже под созданным пользователем `systemd-resolv`, используя аутентификацию по публичному ключу (`publickey`) — рисунок 11. Этот способ входа опаснее парольного, так как:

- не требует ввода пароля при каждом подключении;
- ключ может быть оставлен в файле `authorized_keys`, обеспечивая постоянный доступ;
- такие входы сложнее обнаружить, поскольку они не создают записей о неудачных попытках.

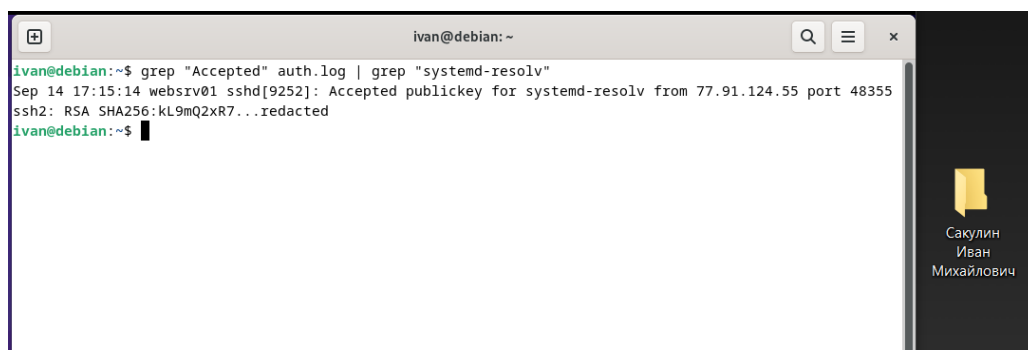


Рисунок 11 — Вход по публичному ключу под пользователем `systemd-resolv`

1.5 Отчёт аудитора

1.5.1 Хронология инцидента

Ключевые события инцидента представлены в таблице 1.

Таблица 1 — Ключевые события инцидента

Время	Событие
12.09 — 14.09 (до 15:08)	Перебор паролей с нескольких внешних IP-адресов (около 13 800 попыток)
14.09 15:08 — 17:08	Интенсивный перебор с IP 77.91.124.55 (около 2400 попыток)
14.09 17:08:56	Успешный вход по паролю под пользователем <code>pavel</code>
14.09 17:09:49	Неудачная попытка <code>sudo cat /etc/shadow</code>
14.09 17:11:17	Создание пользователя <code>systemd-resolv</code> с <code>UID=0</code>
14.09 17:15:14	Вход по публичному ключу под <code>systemd-resolv</code>

1.5.2 Индикаторы компрометации

- IP-адрес злоумышленника: 77.91.124.55
- Скомпрометированная учётная запись: `pavel` (`UID=1008`)
- Созданная учётная запись-бэкдор: `systemd-resolv` (`UID=0`)

1.5.3 Оценка последствий

Злоумышленник получил доступ к системе под учётной записью `pavel`, а затем создал пользователя с правами `root`. Хотя попытки чтения `/etc/shadow` не увенчались успехом, наличие учётной записи с `UID=0` даёт злоумышленнику возможность в любой момент получить полный контроль над сервером (например, через оставленный SSH-ключ). Кроме того, он мог скопировать или модифицировать данные, просматривать логи, устанавливать вредоносное ПО.

1.5.4 Рекомендации

На основе проведённого анализа предлагаются следующие меры:

- 1) Немедленно заблокировать IP-адрес 77.91.124.55 на фаерволе и в `/etc/hosts.deny`.
- 2) Удалить учётную запись `systemd-resolv` и все связанные с ней файлы (домашний каталог, записи в `/etc/passwd` и `/etc/shadow`).
- 3) Сменить пароль пользователя `pavel` и всех других пользователей, чьи пароли могли быть скомпрометированы (рекомендуется полная смена паролей).
- 4) Очистить файлы `authorized_keys` для всех пользователей и удалить подозрительные публичные ключи.
- 5) Настроить мониторинг критичных событий: создание новых пользователей, изменения в `sudoers`, попытки чтения `/etc/shadow`.
- 6) Включить двухфакторную аутентификацию для SSH и ограничить вход по паролю, разрешив только вход по ключам с доверенных IP.
- 7) Настроить `fail2ban` для автоматической блокировки IP после нескольких неудачных попыток.

ЗАКЛЮЧЕНИЕ

В ходе работы был проанализирован журнал аутентификации `auth.log` веб-сервера. Выявлена атака перебора паролей с нескольких внешних IP-адресов, которая привела к компрометации учётной записи `pavel`. Злоумышленник создал пользователя с `UID=0` и организовал постоянный доступ через SSH-ключ. Хотя попытки повышения привилегий не удались, созданный бэкдор представляет серьёзную угрозу. Предложены меры по локализации инцидента, устранению последствий и предотвращению подобных атак в будущем.